

Controls and compliance checklist

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☒	☐	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☐	☒	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance
☒	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers' credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers' data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.

- ☒ ☐ Data integrity ensures the data is consistent, complete, accurate, and has been validated.
- ☐ ☒ Data is available to individuals authorized to access it.

RECOMMENDATIONS:

1. Access Control — Least Privilege & Separation of Duties

Recommendation: Implement role-based access control (RBAC) so employees only access data/systems necessary for their job function. Separate duties for sensitive transactions (e.g., the person who processes refunds shouldn't also approve them).

Why: Currently, all employees can access cardholder data and customer PII/SPII. This violates PCI DSS requirements and significantly increases breach impact and insider-threat exposure.

Compliance driver: PCI DSS (Requirement 7), NIST CSF *Protect* function.

2. Encryption of Cardholder Data

Recommendation: Implement encryption for credit card data at rest (database) and in transit (processing/transmission). Consider tokenization for stored card data.

Why: Unencrypted storage/transmission of cardholder data is a direct PCI DSS violation and a major liability if breached.

Compliance driver: PCI DSS (Requirements 3 & 4).

3. Intrusion Detection System (IDS)

Recommendation: Deploy an IDS (or IDPS) to complement the existing firewall and antivirus, providing visibility into anomalous/malicious network activity.

Why: Firewall and antivirus alone don't detect threats that bypass perimeter defenses; an IDS closes a key detection gap.

Compliance driver: NIST CSF *Detect* function; supports PCI DSS Requirement 10/11.

4. Disaster Recovery & Backups

Recommendation: Develop a disaster recovery plan (DRP) and business continuity plan (BCP), and implement regular, tested backups of critical data (with offsite/cloud redundancy).

Why: No backups currently exist — a ransomware event, hardware failure, or disaster could mean permanent data loss and extended downtime.

Compliance driver: NIST CSF *Recover* function; often required for PCI DSS and cyber-insurance eligibility.

5. Password Policy & Management

Recommendation: Update the password policy to require minimum 8 characters, mixed case, numbers, and special characters. Implement a centralized password management/SSO solution with self-service reset.

Why: Weak password requirements increase breach risk; lack of centralized management creates productivity loss and inconsistent enforcement.

Compliance driver: NIST 800-63B guidance; PCI DSS Requirement 8.

6. Legacy System Monitoring

Recommendation: Establish a formal, documented schedule for monitoring and maintaining legacy/end-of-life systems, with clearly defined intervention/escalation procedures.

Why: Unscheduled, ad hoc monitoring increases the risk that vulnerabilities in unsupported systems go unaddressed.

Compliance driver: NIST CSF *Identify/Protect* functions.

7. Asset Identification & Classification

Recommendation: Conduct a full asset inventory and classify assets by sensitivity/criticality to determine business impact if lost, stolen, or compromised.

Why: The IT department currently can't say which assets are most at risk — this undermines every other control decision.

Compliance driver: NIST CSF *Identify* function (foundational to the whole framework).